

Vulnerability Assessment Report

Passive configuration review of a public demonstration login page.

Prepared for
Future Interns Cyber Security Internship

Prepared by
Keerit Kapoor

Assessment date
20 June 2026

Target
<http://testaspnet.vulnweb.com/login.aspx>

ASSESSMENT TYPE

Non-intrusive browser and HTTP response review. No authentication attempts, injection testing, brute force, fuzzing, scanning, or exploitation was performed.

Document control

Field	Details
Report title	Vulnerability Assessment Report - Passive Assessment
Prepared by	Keerit Kapoor
Internship	Future Interns Cyber Security Internship - Task 1
Target	http://testaspnet.vulnweb.com/login.aspx
Assessment window	20 June 2026 - single-session review
Classification	Educational portfolio report; public demonstration target
Assessment mode	Passive browser inspection and HTTP response-header review

Contents

1. Executive summary	3
2. Scope, safeguards and methodology	4
3. Finding VA-01: Login interface exposed over HTTP	5-6
4. Finding VA-02: Server and framework disclosure	7
5. Risk register and remediation plan	8
6. Limitations, conclusion and references	9

Integrity note

Only findings that are directly supported by the captured evidence are included. This report does not claim SQL injection, cross-site scripting, credential compromise, or any other exploit-based result.

1. Executive summary

This report documents a limited passive security review of the login page at <http://testaspnet.vulnweb.com/login.aspx>. The review relied on a visual browser inspection and the browser Network panel to examine the initial response and visible security context.

Two findings were recorded: one **High** severity transport-security issue and one **Low** severity information-disclosure issue. The high-severity observation is the presence of a username-and-password interface delivered over unencrypted HTTP. The second observation is that the response headers reveal server and framework version details.

Risk level	Count	Finding IDs
High	1	VA-01
Low	1	VA-02
Total	2	Passive evidence only

Overall assessment

Overall result: High priority remediation required

Because the exposed page contains a login interface, encrypted transport should be treated as the immediate priority. This report is not a full penetration test and should not be read as assurance that no other vulnerabilities exist.

Priority recommendation

Move the login page and any authentication submission endpoint to HTTPS, redirect HTTP requests before content is returned, and validate the final configuration through a follow-up review.

2. Scope, safeguards and methodology

Assessment scope

Included	Excluded
Visible login page, browser security indicator, initial HTTP response, and response headers.	Authentication, credential submission, account access, injection testing, brute force, fuzzing, port scanning, automated active scanning, or exploitation.

Method used

1. Open the target page

The login page was opened in a desktop browser and reviewed without entering or submitting any credentials.

2. Confirm browser transport state

The address bar and URL scheme were reviewed to determine whether the page was delivered over HTTP or HTTPS.

3. Inspect the Network request

Browser DevTools - Network was used to select the document request and record the status code and exposed response headers.

4. Classify and report

Findings were assigned a simple High/Low severity rating based on the visible risk and documented with evidence, impact, and remediation.

Rules of engagement observed

The review remained passive. No credentials were used. No payloads, scans, changes to the application, or attempts to exploit the demonstration site were performed.

3. Finding VA-01

Login interface exposed over unencrypted HTTP

HIGH

Finding ID	VA-01	Severity	High
Category	Transport security / credential exposure risk	Evidence	HTTP URL, browser "Not secure" indicator, login form

Description

The assessed login page is served using **HTTP**, not **HTTPS**. The page visibly contains username and password fields while the browser displays a "Not secure" indicator. HTTP does not provide transport-layer encryption or integrity protection for the page content.

Impact

A person positioned on the network path could potentially read or modify traffic sent to or from an HTTP-delivered login experience. This increases the risk of credential exposure, session manipulation, phishing-style page alteration, and loss of user trust. The form submission endpoint was not tested, so this report does not claim that credentials were submitted in cleartext; it documents the high-risk condition created by delivering the authentication interface over HTTP.

Risk rationale

The severity is rated High because authentication pages handle credentials and should be accessible only via strong transport protection. OWASP authentication guidance states that the login page and authenticated pages should be accessed over TLS.

Recommended outcome

No login-related page should be reachable in a usable state over HTTP. Requests should be redirected to HTTPS before page content is returned.

3. Finding VA-01 - evidence and remediation

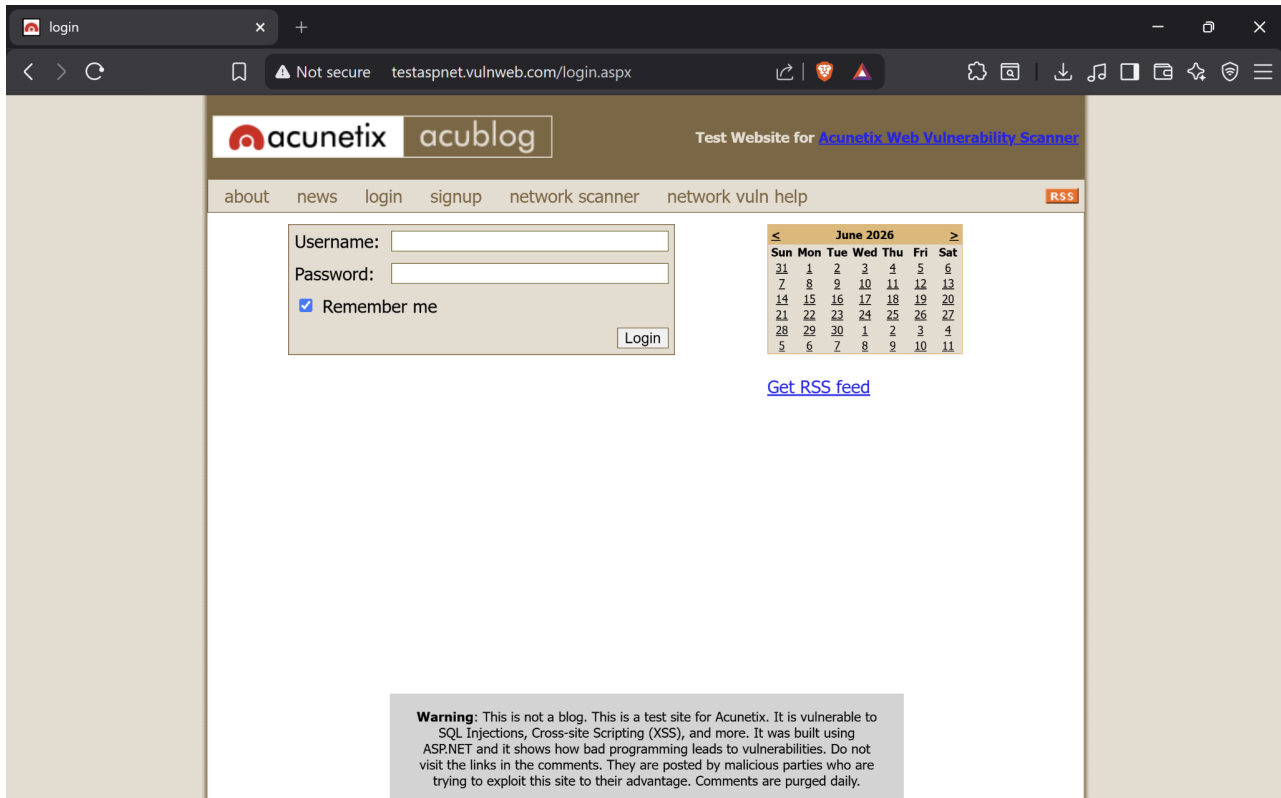


Figure 1. The browser shows "Not secure" while displaying the target HTTP login page and its username/password form. Screenshot captured by the assessor.

Remediation

Priority	Recommended action	Validation criterion
1 - Immediate	Enable HTTPS for the login page and redirect all HTTP requests to the HTTPS equivalent before content is delivered.	Opening the HTTP URL results in a secure HTTPS URL before the login form appears.
2 - High	Configure HSTS after HTTPS is fully deployed and validated.	HTTPS response includes an appropriate Strict-Transport-Security header.
3 - High	Use Secure, HttpOnly, and appropriate SameSite cookie attributes for authentication cookies.	Set-Cookie headers reflect the approved attributes and no sensitive session identifier is exposed over HTTP.

Owner and target date

Suggested owner: application owner or infrastructure administrator. Suggested target: remediate before using the application for any real users or real credentials.

4. Finding VA-02

Server and framework version disclosure in response headers

LOW

Finding ID	VA-02	Severity	Low
Category	Information disclosure / technology fingerprinting	Evidence	Server and framework headers exposed in browser DevTools

Description and evidence

The initial document response disclosed the following technology details in HTTP headers: **Server: Microsoft-IIS/8.5, X-AspNet-Version: 2.0.50727**, and **X-Powered-By: ASP.NET**. These headers allow a visitor to fingerprint the web server and application framework more precisely.

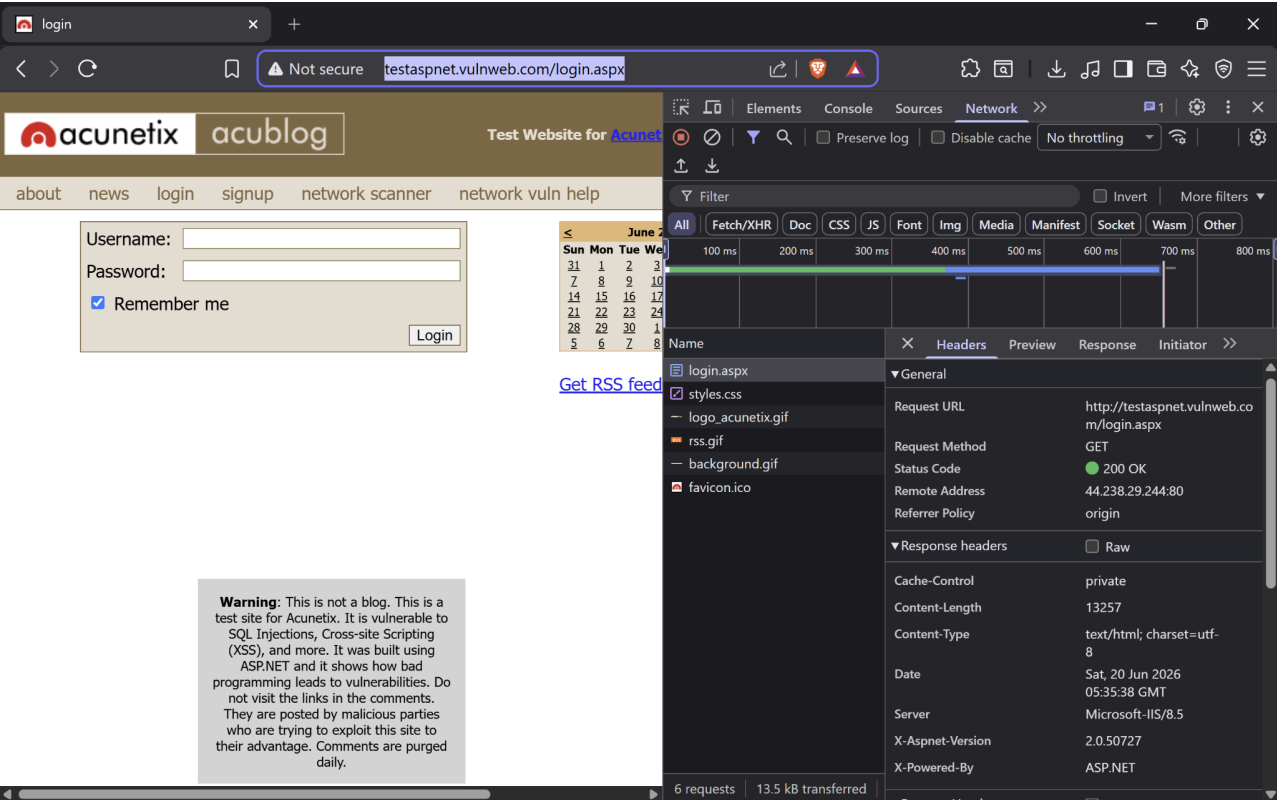


Figure 2. Browser DevTools response headers for the document request. The image visibly shows Microsoft-IIS/8.5, X-AspNet-Version: 2.0.50727, and X-Powered-By: ASP.NET.

Impact and remediation

Technology disclosure does not prove a vulnerability by itself. It can, however, reduce the effort required for reconnaissance and help an attacker prioritize product-specific research. Limit unnecessary response headers, avoid exposing exact version numbers where feasible, keep the platform patched, and validate the change with a fresh external header review.

5. Risk register and remediation plan

ID	Finding	Severity	Business impact	Primary remediation
VA-01	Login interface exposed over HTTP	High	Potential loss of confidentiality and integrity for authentication traffic; user trust impact.	Serve login flow over HTTPS only; redirect HTTP; deploy HSTS after validation.
VA-02	Server and framework version disclosure	Low	Improves an attacker's ability to fingerprint the stack and focus reconnaissance.	Suppress unnecessary product/version headers and maintain supported, patched software.

Suggested remediation sequence

Phase	What to do	Success check
Immediate	Remove HTTP access to the usable login interface and deploy a valid HTTPS configuration.	A browser never displays the login form under an HTTP/"Not secure" context.
Hardening	Add HSTS once HTTPS is stable, set secure cookie attributes, and review common response headers.	Configuration is confirmed using browser DevTools or a non-intrusive header review.
Hygiene	Suppress unnecessary version disclosure and keep the web server/framework within supported patch levels.	Product/version headers no longer expose avoidable stack detail.
Re-test	Repeat the passive review after the changes. Expand scope only with documented authorization.	Evidence screenshots and report are updated to show the remediated state.

Retest statement

A finding should only be marked remediated after the evidence shows the protected configuration in place. This report contains no claim of remediation because no changes were made during the assessment.

6. Limitations, conclusion and references

Assessment limitations

- The review was limited to the visible login page and its initial HTTP response captured in one browser session.
- No credentials were entered, no login request was submitted, and no authenticated functionality was assessed.
- No port scan, vulnerability scanner, injection test, brute-force test, directory enumeration, or exploit attempt was performed.
- The report documents only evidence visible in the included screenshots and should not be interpreted as a complete security assurance statement.

Conclusion

The passive review identified a high-priority issue: a login interface is available over unencrypted HTTP. The immediate corrective action is to require HTTPS before serving authentication content. A secondary low-severity issue is the exposure of server and framework version information through response headers. Addressing both findings will reduce avoidable attack surface and better align the login experience with common web-security expectations.

References

[1] OWASP Authentication Cheat Sheet. Guidance: login and authenticated pages should be accessed over TLS. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

[2] OWASP Transport Layer Security Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html

[3] OWASP Web Security Testing Guide - Fingerprint Web Server. https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server

[4] OWASP HTTP Security Response Headers Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers_Cheat_Sheet.html

Portfolio note

For the Future Interns submission, upload this PDF to the repository root as Vulnerability_Assessment_Report.pdf and keep the two source screenshots in the screenshots folder.